

Guía de seguridad y buenas prácticas en base de datos

Redactado por:	Aprobado por:
<i>Oficina de Ciberseguridad</i>	<i>Javier Zapata Victori (CISO)</i>

CONTROL DE CAMBIOS RESPECTO A ÚLTIMA VERSIÓN		
Versión	Fecha	Modificación
1	28/03/2023	Versión Inicial

INDICE

1. INTRODUCCIÓN Y ALCANCE	4
2. OBJETIVO	4
3. CONTROLES DE SEGURIDAD	4
3.1. CONTROL DE ACCESO	4
3.1.1. GESTIÓN CENTRALIZADA DE ACCESOS	4
3.1.2. LIMITACIÓN DE PERMISOS	5
3.1.3. SEGREGACIÓN DE FUNCIONES	5
3.1.4. REVOCACIÓN DE PERMISOS	5
3.1.5. POLÍTICA DE CONTRASEÑAS	6
3.1.6. LIMITACIÓN DE USO DE USUARIOS GENÉRICOS	6
3.1.7. ACCESO A LOGS	6
3.2. AISLAMIENTO DE ENTORNO	6
3.2.1. SEGMENTACIÓN DE RED	6
3.2.2. SEGREGACIÓN DE ENTORNOS	6
3.2.3. BLOQUEO DE DESCARGA DE DATOS A DISPOSITIVOS EXTERNO	6
3.3. MONITORIZACION	6
3.3.1. INTEGRACIÓN CON HERRAMIENTAS DE MONITORIZACIÓN Y REGISTRO DE LOG	6
3.3.2. SINCRONIZACIÓN DE RELOJES	7
3.3.3. TRAZABILIDAD E INTEGRIDAD DE LOGS	7
3.3.4. RETENCIÓN DE LOGS	7
3.3.5. NOTIFICACIÓN DE ASIGNACIÓN DE PERMISOS	7
3.3.6. HERRAMIENTAS DE MONITORIZACIÓN DE INCIDENTES Y VULNERABILIDADES	7
3.4. CIFRADO	7
3.4.1. CIFRADO EN TRÁNSITO	7
3.4.2. CIFRADO DE BASES DE DATOS	8
3.4.3. ALMACENAMIENTO DE CLAVES DE CIFRADO	8
3.4.4. CIFRADO DE LOGS	8
3.4.5. CIFRADO DE BACKUPS	8
3.5. MANTENIMIENTO	8
3.5.1. MANTENIMIENTO	8
3.5.2. GESTIÓN DE VULNERABILIDADES	8
3.5.3. PARCHES DE SEGURIDAD	8
3.5.4. INVENTARIADO DE BBDD	8

3.5.5.	<i>HARDENING DE BBDD</i>	9
3.6.	TRASMINISION DE DATOS	9
3.6.1.	<i>TRANSMISIÓN DEL DATO</i>	9
3.6.2.	<i>ESTABLECER UN PROCEDIMIENTO DE APROBACIÓN ANTES DE MOVER DATOS FÍSICOS</i>	9
3.6.3.	<i>CADENA DE CUSTODIA</i>	9
3.7.	POLITICAS DE RESPALDO	9
3.7.1.	<i>CONFIGURACIÓN DE BACKUPS DE BBDD</i>	9
3.7.2.	<i>DESTRUCCIÓN DEL DATO</i>	9
3.7.3.	<i>DEFINICIÓN DE DATOS QUE SE CONSERVARÁN O ELIMINARÁN</i>	9
3.7.4.	<i>PRUEBAS DE RECUPERACIÓN</i>	9
4.	REFERENCIAS	10

1. INTRODUCCIÓN Y ALCANCE

La seguridad de la base de datos es esencial para garantizar la confidencialidad, integridad y disponibilidad de la información almacenada en ella. Con el aumento del uso de la tecnología y la cantidad de datos almacenados, también ha aumentado el riesgo de infracciones de seguridad. Es por eso por lo que es vital implementar medidas de seguridad adecuadas y seguir buenas prácticas para proteger los datos importantes de la organización. Esta guía está diseñada para proporcionar una comprensión básica de los conceptos de seguridad de base de datos y brindar recomendaciones prácticas para ayudar a proteger su base de datos.

El alcance de este documento es definir una estrategia de seguridad de bases de datos que abarque los siguientes puntos:

1. Identificación de los datos sensibles: Identificar qué datos son críticos para el negocio y requieren una protección adicional.
2. Control de acceso: Implementar medidas de control de acceso para garantizar que solo las personas autorizadas tengan acceso a los datos. Esto puede incluir la autenticación y autorización, así como la asignación de permisos y roles.
3. Cifrado: Utilizar encriptación para proteger los datos sensibles y cumplir con los requisitos normativos.
4. Copias de seguridad y recuperación: Crear y mantener copias de seguridad de los datos y tener un plan de recuperación de desastres para garantizar la disponibilidad de los datos en caso de emergencia.
5. Monitoreo y registro: Monitorear y registrar el acceso y las actividades de la base de datos para detectar posibles violaciones de seguridad.
6. Actualizaciones y parches: Mantener el software de la base de datos y el sistema operativo actualizado con las últimas actualizaciones de seguridad.
7. Compliance: cumplir con las normativas y regulaciones aplicables para proteger los datos y evitar sanciones legales.
8. Capacitación: educar y capacitar a los empleados sobre las buenas prácticas de seguridad de la base de datos y cómo detectar y evitar posibles amenazas.

2. OBJETIVO

La presente guía tiene como objetivo la protección proactiva de los datos de ataques internos y externos, reducir la exposición de datos a usuarios de TI privilegiados y autorizados, y proteger todas las bases de datos, incluidas la producción y la no pre-productiva.

3. CONTROLES DE SEGURIDAD

Los controles de seguridad de base de datos son medidas implementadas para proteger la información almacenada en una base de datos contra accesos no autorizados, modificaciones, eliminaciones, interrupciones, y otros ataques.

Estos controles ayudan a garantizar la confidencialidad, integridad y disponibilidad de los datos.

3.1. CONTROL DE ACCESO

3.1.1. GESTIÓN CENTRALIZADA DE ACCESOS

Se deben implementar las medidas necesarias para delimitar responsabilidad en cada sistema cuando existen sistemas interconectados, donde la identificación debe realizarse a través de un controlador de dominio gestionado de forma centralizada.

3.1.2. LIMITACIÓN DE PERMISOS

Se debe crear roles de usuario donde se puedan garantizar los privilegios a este nivel. Esta agrupación creada para categorizar a los usuarios o identificadores ayudará en la creación de perfiles de seguridad por agrupación de tipo de trabajos dentro de la base de datos.

Dentro de los roles que es posible encontrar, hay algunos básicos y comunes que se deberían tener en cuenta y crearlos en concordancia (estos no son los únicos roles que se pueden usar, pero si los mínimos recomendados).

- Rol de Administrador de seguridad: Son los gestores de seguridad, además de las cuentas de los usuarios, las auditorías que deban hacerse o la gestión de las claves de cifrados.
- Rol de Administrador de Base de Datos: Involucran una gran cantidad de tareas, desde la generación de base de datos, la actualización del software, comprobación del performance o el buen funcionamiento, el inicio y apagado de la base de datos e incluso de crear el respaldo que necesite la base de datos. Estos usuarios deberían tener privilegios de administración y modificación de las bases de datos.

Se deberá revisar este rol de manera periódica para comprobar que los identificadores asociados a este rol son los correctos.

- Rol de usuario de explotación de datos: Este rol es adecuado para aquellos usuarios que son los encargados de hacer explotación y minería de datos de carácter de negocio. Estos usuarios suelen tener solo acceso de lectura.
- Rol de administrador de la aplicación: Pueden ser cuentas que solo cuenten con los privilegios para la actualización y el parcheo de la aplicación.
- Rol de aplicación: En esta categoría se podría englobar las cuentas de Identificadores que vengan por parte de aplicaciones externas o internas que necesiten ver los datos. En este caso, suelen tener acceso de lectura y escritura en las tablas o datos necesarios para su aplicación.
- Rol de usuarios habituales de base de datos: En este caso están englobados los identificadores con acceso restringidos a sus datos específicos, tablas, vistas y objetos.
- Rol de administración del sistema operativo de base de datos: En este caso no podrán crear usuarios locales con acceso a datos sensibles y tampoco podrán tener acceso a datos sensibles, es decir, podrán hacer todas las operaciones de operación y mantenimiento sin poder leer ficheros cifrados.

3.1.3. SEGREGACIÓN DE FUNCIONES

La segregación de funciones es una característica de control interno que busca no permitir que un usuario pueda iniciar, procesar, finalizar y hasta eliminar sus acciones, sin la necesidad de que un segundo o tercero intervengan a manera de control.

Se recomienda diseñar una matriz de segregación de funciones asegurándose que incorpora todas las actividades críticas para evitar conflictos de intereses.

3.1.4. REVOCACIÓN DE PERMISOS

Se ha de establecer un procedimiento de revocación de permisos a los recursos con el objetivo de limitar el acceso a personas que han terminado su labor en el proyecto o que ya no pertenezcan a la compañía en un plazo de máximo 24 horas.

3.1.5. POLÍTICA DE CONTRASEÑAS

Se debe aplicar la política de contraseñas marcada por los estándares de QuirónSalud para usuarios administrativos y usuarios de servicio.

3.1.6. LIMITACIÓN DE USO DE USUARIOS GENÉRICOS

Con el objetivo de garantizar la trazabilidad de los usuarios, el acceso mediante usuarios personales genéricos no está permitido y las contraseñas no deben compartirse ni almacenar en archivos en claro.

En el caso de que se requieran usuarios de aplicación deben estar correctamente identificados por el nombre del aplicativo y asociados a un responsable.

3.1.7. ACCESO A LOGS

Se deberán registrar todos los inicios de sesión en el servidor de la base de datos y el sistema operativo, y también registra todas las operaciones realizadas en datos confidenciales. Las auditorías estándar de seguridad de la base de datos deben realizarse regularmente.

3.2. AISLAMIENTO DE ENTORNO

3.2.1. SEGMENTACIÓN DE RED

La conexión a nivel de red ha de ser restringida por defecto y solo se abrirá conexión para lo estrictamente necesario siendo previamente autorizado por Oficina de Seguridad.

3.2.2. SEGREGACIÓN DE ENTORNOS

Se deben establecer medidas y políticas implementadas para asegurar que los diferentes entornos de bases de datos estén debidamente separados y aislados entre sí. Esto puede incluir medidas técnicas como la configuración de firewalls y reglas de enrutamiento, así como políticas y procedimientos para garantizar que los cambios y pruebas solo se realicen en los entornos adecuados.

3.2.3. BLOQUEO DE DESCARGA DE DATOS A DISPOSITIVOS EXTERNO

Los servidores de base de datos han de integrarse con la herramienta de gestión centralizada permitiendo aplicar el bloqueo de cualquier dispositivo externo como USB, CD/DVD, tarjetas de memoria externa, discos duros, etc.

3.3. MONITORIZACION

3.3.1. INTEGRACIÓN CON HERRAMIENTAS DE MONITORIZACIÓN Y REGISTRO DE LOG

Se debe establecer la monitorización y registro de log para garantizar una adecuada supervisión y seguimiento de los sistemas de bases de datos. Esto puede incluir la monitorización en tiempo real de las métricas de rendimiento y disponibilidad, así como el registro y análisis de eventos y errores para detectar y resolver problemas.

Las herramientas de monitorización y registro de log deben estar debidamente integradas con los sistemas de bases de datos y debe estar disponible para todos los entornos (desarrollo, pruebas y producción) para garantizar una supervisión continua.

Además, es importante establecer políticas y procedimientos para asegurar que los registros de log sean adecuadamente almacenados, protegidos y analizados para detectar y resolver problemas.

3.3.2. SINCRONIZACIÓN DE RELOJES

Se ha de establecer un mismo servidor NTP y el mismo huso horario.

3.3.3. TRAZABILIDAD E INTEGRIDAD DE LOGS

Se ha de establecer trazabilidad e integridad de logs de bases de datos en el que se garanticen que los registros de log de las bases de datos sean precisos, completos y no modificados.

La trazabilidad se refiere a la capacidad de rastrear los cambios realizados en una base de datos y determinar quién los realizó, cuándo se realizaron y qué cambios se realizaron. Esto se logra mediante la implementación de un sistema de registro de transacciones que registra todas las operaciones realizadas en la base de datos.

La integridad de los logs se refiere a la capacidad de garantizar que los registros de log no han sido modificados o alterados de alguna manera. Esto se logra mediante la implementación de mecanismos de autenticación y cifrado para proteger los registros de log contra modificaciones no autorizadas.

Además, es importante establecer políticas y procedimientos para asegurar que los registros de log sean adecuadamente almacenados y respaldados y que se realice un monitoreo y análisis continuo para detectar y resolver problemas.

3.3.4. RETENCIÓN DE LOGS

Los logs y eventos tienen que archivarse con un periodo de retención de al menos 1 año acorde a las políticas de seguridad corporativas, necesidades de negocio y cumplimiento regulatorio.

3.3.5. NOTIFICACIÓN DE ASIGNACIÓN DE PERMISOS

La asignación de permisos de administración ha de ser aprobada por la Oficina de Ciberseguridad y se ha de establecer un procedimiento de notificación mediante envío de email al SOC y a la Oficina de Ciberseguridad si se asigna un rol de administrador a BBDD.

3.3.6. HERRAMIENTAS DE MONITORIZACIÓN DE INCIDENTES Y VULNERABILIDADES

Deben instalarse agentes de seguridad (SCCM, DATP, Trend Micro) en los servidores de bases de datos para dar identificar incidentes de seguridad cubriendo temas como el a las actualizaciones de seguridad.

3.4. CIFRADO

3.4.1. CIFRADO EN TRÁNSITO

Todos los datos, incluidos los datos en la base de datos y los datos de credenciales, deben protegerse con el mejor cifrado de su clase mientras están en reposo y en tránsito. Todas las claves de cifrado deben manejarse de acuerdo con las pautas de mejores prácticas.

El tráfico de acceso remoto entre aplicaciones y las bases de datos tiene que ser cifrado punto a punto usando protocolos seguros como TLSv1.2

3.4.2. CIFRADO DE BASES DE DATOS

Se ha de definir el nivel de cifrado en función del nivel de criticidad de datos, en caso de incumplimiento, el cifrado ofrece una línea final de defensa contra compromisos. Cualquier herramienta que se elija debe incluir capacidades de cifrados flexibles que puedan proteger los datos en entornos locales, en la nube, híbridos o de varias nubes.

3.4.3. ALMACENAMIENTO DE CLAVES DE CIFRADO

Las claves de cifrado de BBDD se han de almacenar de forma segura (KeyVault, Keepass) y se ha de definir un custodio de claves. A su vez, se tiene que ser capaz de identificar cualquier acceso/uso/modificación de las claves.

3.4.4. CIFRADO DE LOGS

Los logs y eventos registrados no pueden contener información sensible y han de proteger mediante soluciones de cifrado seguras.

3.4.5. CIFRADO DE BACKUPS

Las copias de seguridad de bases de datos deberán estar cifradas usando protocolos de cifrado robustos.

3.5. MANTENIMIENTO

3.5.1. MANTENIMIENTO

Se deberá establecer y mantener un procedimiento de gestión de cambios incluyendo relaciones de BBDD con aplicativos y contactos responsables de los activos.

3.5.2. GESTIÓN DE VULNERABILIDADES

Las bases de datos tienen que integrarse con herramientas de gestión de vulnerabilidades, para realizar escaneos, detectar y registrar vulnerabilidades

3.5.3. PARCHES DE SEGURIDAD

Se han de ejecutar evaluaciones periódicas de parcheo de servidores siguiendo plazos específicos que tenga en cuenta las circunstancias específicas del aplicativo y la infraestructura involucrada.

Por lo que se recomienda utilizar siempre la última versión del software de administración de la base de datos y aplica todos los parches tan pronto como se emitan.

3.5.4. INVENTARIADO DE BBDD

Se ha de mantener un inventario de infraestructura, revisado y aprobado periódicamente, deberá contener la siguiente información:

- Nombre del servidor/BBDD/Nombre de la aplicación.
- Responsable del activo y datos de contacto.

- Criticidad.
- Entorno (dev/test/prod).
- Sistema Operativo/ Versión de base de datos/ Versión de aplicación.

3.5.5. HARDENING DE BBDD

Los servidores de BBDD deben involucrar un conjunto de técnicas, herramientas y las mejoras prácticas para reducir vulnerabilidades para ello se debe establecer hardening para en los servidores de BBDD.

3.6. TRASMINISION DE DATOS

3.6.1. TRANSMISIÓN DEL DATO

El intercambio de datos de clientes ha de transmitirse de forma controlada y usando canales cifrados con protocolos seguros (Ej: sFTP sobre TLSv1.2).

3.6.2. ESTABLECER UN PROCEDIMIENTO DE APROBACIÓN ANTES DE MOVER DATOS FÍSICOS

Ante cualquier movimiento de datos físico (discos duros, migración de bases de datos, backups, etc) se ha de detallar el proceso de transporte o transmisión y debe ser aprobado por seguridad y LOPD.

3.6.3. CADENA DE CUSTODIA

Se ha de registrar la cadena de custodia en todos los puntos de transferencia de datos y establecer un responsable durante el periodo de custodio cada vez que se transporten dispositivos de almacenamiento físico o copias de seguridad que contienen datos de clientes altamente confidenciales o restringidos.

3.7. POLITICAS DE RESPALDO

3.7.1. CONFIGURACIÓN DE BACKUPS DE BBDD

Todas las copias de seguridad, copias o imágenes de la base de datos deben estar sujetas a los mismos controles de seguridad (o igualmente estrictos) que la base de datos, se ha de establecer una política de backup para garantizar el respaldo de las bases de datos en caso de recuperación ante incidentes.

3.7.2. DESTRUCCIÓN DEL DATO

Se ha de eliminar/destruir irrevocablemente y de forma segura archivos electrónicos u objetos que contengan datos altamente confidenciales o restringidos después de que los datos ya no sean necesarios.

3.7.3. DEFINICIÓN DE DATOS QUE SE CONSERVARÁN O ELIMINARÁN

Se ha de definir un proceso mediante el cual se especifique la duración, limpieza y método de purga de los datos de las copias de seguridad.

3.7.4. PRUEBAS DE RECUPERACIÓN

Se han de realizar pruebas de recuperación ante incidentes para comprobar que, en caso de pérdida de datos, las copias de seguridad permitirían recuperar la configuración y los datos almacenados en las BBDD.

4. REFERENCIAS

[1] *CCN-CERT_BP24-RS en Bases de Datos (BBDD).pdf* Disponible en: <https://www.ccn-cert.cni.es/informes/informes-de-buenas-practicas-bp/6353-ccn-cert-bp-24-recomendaciones-de-seguridad-en-bases-de-datos/file.html>